

PRS821S PROGRAMMING FOR SECURITY PROFESSIONAL, SEM 1, 2026

WEEK 5A LECTURE NOTES

PROACTIVE CONTROLS

Several Domains/Sectors Of Cyber Security

Security is becoming increasingly crucial to protect individuals, organisations, and governments from growing cyber threats. Several domains make up the broad field of Security, as follows:

Network Security

Network security focuses on protecting the underlying infrastructure and components that enable communication over the Internet. This includes safeguarding hardware such as routers, switches, and firewalls, as well as protocols such as WiFi, Bluetooth, LTE, and VoIP. The main goal of network security is to prevent unauthorised access and misuse.

Critical aspects of network security include:

- Firewalls – Hardware or software that monitors incoming and outgoing network traffic and blocks threats
- Intrusion detection systems (IDS) – Systems that identify suspicious activity or policy violations on a network
- Virtual Private Networks (VPNs) – Encrypted connections that allow remote users to access a private network over the Internet securely
- Access controls – Policies and procedures that restrict access to networks and resources only to authorised users

Application Security

Application security involves identifying, fixing, and safeguarding vulnerabilities and weaknesses in software applications that attackers could exploit. This is crucial as applications are increasingly used to store and access sensitive data through the Internet.

Critical aspects of application security include:

- Input validation – Ensuring all input to an application is valid before processing to prevent attacks like code injection or buffer overflow
- Authentication and access controls – Requiring login credentials and appropriate permissions to access applications and data
- Encryption – Encoding data at rest and in transit to protect confidentiality and data integrity

Example of a python program with encryption is listed below:

```
from cryptography.fernet import Fernet
# Generate a key and store it securely (do this once)
key = Fernet.generate_key()
cipher_suite = Fernet(key)
# Encrypt data before storing it in the database
message = "My highly sensitive data"
encrypted_message = cipher_suite.encrypt(message)
print(encrypted_message)
# Decrypt data when retrieving it
decrypted_message = cipher_suite.decrypt(encrypted_message)
print(decrypted_message.decode())
```

- Security testing – Systematically testing applications to uncover security flaws before deployment
- DevOps, DevSecOps or DevOpsSec– Building security practices into every phase of the software development lifecycle

Cloud Security

Cloud security addresses vulnerabilities unique to the cloud computing environment. As more data and applications migrate to the cloud, protecting these hosted services requires new approaches compared to traditional on-premise solutions.

Critical aspects of cloud security include:

- Identity and access management – Providing appropriate access controls and minimising overexposed credentials
- Cloud encryption – Encrypting data while stored on cloud servers and in transit
- Visibility and analytics – Monitoring account activity and assets across cloud services
- Configuration audits – Checking for misconfigurations in complex cloud environments that could introduce vulnerabilities
- Vendor lock-in avoidance – Being able to migrate applications and data from one cloud provider to another

Information Security

Information security focuses on preserving confidentiality, integrity, and digital data availability. This means ensuring that information is protected from unauthorised access, preventing improper modification, and ensuring accessibility for authorised users.

Critical aspects include:

- Data loss prevention – Policies and technologies that stop users from sending sensitive data outside a system
- Data governance – The overall management of data assets and security controls

- Data classification – Categorising data by sensitivity levels and applying appropriate protections
- Disaster recovery and business continuity – Plans that allow restoration and continuity of systems and data after a security breach or disaster
- End-user education – Training all employees on cybersecurity best practices for handling company information

Disaster Recovery

Disaster recovery involves planning for urgent responses when cyberattacks or system failures occur to restore services and data to a working state. An incident response plan prepared beforehand allows organisations to efficiently allocate resources, communicate internally, coordinate across teams, and take the technical steps needed to recover.

Critical aspects of disaster recovery include:

- Impact assessment – Evaluating the extent of damage and identifying affected assets after an event occurs
- Data and hardware backup – Maintaining accessible backups of critical data and infrastructure
- Emergency communications – Contact trees, call lists, automated notifications to inform relevant teams
- Restoration procedures – Steps for safely restoring compromised systems from backups
- Response testing – Regularly testing disaster recovery plans end-to-end to improve effectiveness

Operational Technology (OT) Security

OT security safeguards industrial control systems, SCADA devices, Internet of Things (IoT) networks, and other connected equipment in critical infrastructure sectors like energy, transportation, and manufacturing. These devices and networks interact directly with physical processes, which makes them vulnerable to cyberattacks with kinetic world consequences.

Critical aspects of OT security include:

- Network segmentation – Isolating and protecting OT systems by keeping them separate from IT networks
- Access control – Establishing layered protections restricting access to only authorised users
- Monitoring – Tracking all activity on OT networks to identify threats
- Patch management – Regularly installing patches and updates to remediate vulnerabilities
- Resilience and redundancy – Designing OT environments not to fail dangerously if compromised in an attack

Mobile Security

Mobile security protects smartphones, tablets, and other mobile devices from evolving cyber threats aimed at these ubiquitous targets. Attack vectors like malicious apps, unsafe WiFi networks, or phishing links can allow attackers to gain access, modify data, or track device owners.

Critical aspects of mobile security include:

- Application vetting – Testing new apps for malware or unnecessary permissions before installation
- Authentication methods – Using strong PINs, patterns, or biometrics to prevent unauthorised access
- Data encryption – Protecting sensitive mobile data if a device is lost or stolen
- Security updates – Regularly patching mobile operating systems and apps
- Secure connectivity – Using trusted WiFi networks and VPNs to prevent eavesdropping

Cryptography

Cryptography is vital to many cybersecurity domains since it allows for secure communication and safe data storage, even on insecure networks like the Internet. This science focuses on developing and deploying encryption and protecting keys and passwords.

Critical aspects of Cryptography include:

- Encryption algorithms – Mathematical techniques to transform plain text into indecipherable ciphertext
- Public critical infrastructure (PKI) – Framework enabling secure digital communication and data integrity
- Key management – Generating, distributing, storing, revoking, and destroying the secret keys used in cryptographic operations
- Quantum-safe cryptography – Developing new algorithms resistant to code-breaking from quantum computers
- Steganography – Concealing messages inside images, video clips, or other innocuous-looking data

Risk Management

Cybersecurity risk management involves identifying critical assets, assessing vulnerabilities, understanding cyber threats, and choosing appropriate safeguards. This allows an organisation to make prudent decisions about which risks to accept and which to mitigate by directing resources to the proper cyber defences.

Critical aspects include:

- Asset valuation – Estimating the sensitivity and importance of data to set security priorities

- Risk assessments – Methodically reviewing infrastructure and controls to identify weaknesses
- Threat modelling – Researching real-world attacks likely to target an organisation's crown jewels
- Control baselines – Cataloging required security capabilities based on data classifications
- Security frameworks – Adopting standardised models for cyber risk management like NIST or ISO

Incident Response

Cybersecurity incident response focuses on the plans, procedures, and teams required to quickly identify, contain, eradicate, and recover from security events like data breaches, DoS attacks, or insider threats. Minimising impact requires agile coordination across security operations, IT, legal, PR, and executives.

Critical aspects include:

- Monitoring and alerting – Enabling security ops teams to spot incidents in progress
- Investigation and forensics – Technically analysing attacks to learn root causes and assess impact
- Notification – Informing victims as required by breach disclosure laws
- Damage control – Isolating and repairing affected systems, securing evidence
- Post-incident review – Assessing the effectiveness of the response to guide future improvements

Security Operations

Security operations involve continually monitoring infrastructure, endpoints, networks, data, logs, and cloud resources to identify threats and prevent cyber attacks. This function is a 24/7 cyber command centre, often relying on Security Information and Event Management (SIEM) software to track and analyse activity across an entire IT environment.

Critical aspects include:

- Security monitoring – Watching all systems centrally to spot suspicious events more quickly
- Incident response – Executing playbooks to contain, eradicate, and recover from attacks
- Digital forensics – Capturing extensive system logs and data to uncover root causes
- Security automation – Scripting repeatable processes for threat detection and mitigation
- Defence coordination – Sharing intelligence and coordinating protections with partners

Governance, Risk Management, and Compliance (GRC)

GRC represents integrated processes for aligning cybersecurity programs with business objectives, managing risk appetite, and adhering to legal, regulatory and industry compliance standards. This involves extensive documentation, audits, control testing, and executive governance.

Critical aspects include:

- Policies and standards – Setting security requirements for technology, staff, and vendors
- Control objectives – Defining required safeguards based on risk tolerance
- Audits – Validating that prescribed controls are correctly implemented
- Benchmarks and metrics – Measuring program effectiveness to guide improvements
- Board reporting – Keeping executives and directors informed on cyber risk posture

Security Architecture

Security architecture focuses on baking comprehensive protections into the design, integration, and management of IT systems, networks, and infrastructure. This proactive approach identifies security needs early on and allows controls to be tightly woven into technology blueprints rather than bolted on later.

Critical aspects include:

- Secure SDLC – Making security central to dev ops pipelines and software development lifecycles
- Defense-in-depth – Layering complementary controls so weaknesses in one are covered by another
- Zero trust model – Designing environments assuming breach and verifying all access
- Privacy by design – Architecting full data protections upfront per privacy regulations
- Cloud security posture management – Applying and managing controls across complex cloud environments

Vendor and Third-Party Cyber Risk Management

Vendor cyber risk has become a top concern with the extensive reliance on cloud services, managed service providers, contractors, and IT supply chains. A stringent review of partners' security controls and practices is required to avoid weak links that result in consequential breaches.

Critical aspects include:

- Due diligence reviews – Extensively vetting vendor security before partnerships
- Contract terms – Clearly defining security responsibilities between parties
- Cloud security alliances – Joining industry groups that promote cloud control assurance

- Monitors – Ongoing reviews of partners' control environments
- Incident response coordination – Structuring how joint incidents will be managed

Physical and Personnel Security

Overlooked physical security exposures can undermine even the most technically sophisticated cyber defences. Likewise, negligence, errors, or malicious insiders remain persistent threats. Tangible safeguards and staff screening controls are crucial to holistic organisational security.

Critical aspects include:

- Physical access controls – Electronic badge readers, guards, fencing, alarms, and surveillance
- Datacenter protections – Resilient power, fire suppression, climate and entry controls
- Background checks – Vetting staff for criminal records, conflicts or concerning affiliations
- Security awareness training – Educating personnel on cyber hygiene and incident reporting
- Workplace surveillance – Monitoring network activity and communications for insider threats

Intelligence and Threat Analysis

Effective cybersecurity requires understanding the likely adversaries' motives, capabilities and attack patterns to implement the proper defences. Threat intelligence fuels this by gathering information about cyber criminals, hacktivists, insider risks, business competitors and nation-states.

Critical aspects include:

- Strategic intelligence – Forecasting risks connected to business plans and strategies
- Tactical intelligence – Tracking cybercrime groups, exploit availability and emerging attack trends
- Dark web monitoring – Mining hidden chatting platforms and marketplaces frequented by criminals
- Attack surface analysis – Modeling and monitoring externally visible vulnerabilities adversaries could target
- Attribution analysis – Technically profiling attack indicators to determine the likely source

Cyber Regulation and Policy

As cyber incidents grow more severe and frequent, governments enact new regulations and policies to improve baseline security, requiring breach notification and

boosting cross-sector collaboration. You'll need to understand applicable laws and actively track new legislation.

Critical aspects include:

- Data protection laws – Compliance with GDPR, CCPA and other strict privacy rules
- Infrastructure regulations – Adherence to NERC-CIP for energy companies, NIST IR 8276 for federal contractors
- Mandatory reporting – Notifying regulators about cyber incidents per SEC, HHS or state rules
- Government assistance – Taking advantage of cyber threat intelligence sharing programs
- Policy advocacy – Providing input to lawmakers crafting bills related to technology laws

Forensics and E-Discovery

Closely related to incident response, cyber forensics involves deeply analysing IT systems and data to establish facts regarding a security event's cause, scope, and impact. Practitioners preserve evidence, document the chain of custody, and ultimately provide technical explanations that stand up in court.

Critical aspects include:

- System imaging – Safely collecting full-disk copies of affected computers to analyse securely
- Media analysis – Pulling forensic artefacts from logs, files, endpoint RAM, or hard drives
- Mobile device forensics – Cracking, imaging and scouring locked, encrypted phones or tablets
- Legal standards – Following evidentiary procedures compliant with federal and state court rules
- Expert testimony – Acting as a court-certified expert witness regarding forensic processes and findings

Security Testing and Auditing

Rigorously testing systems and controls for weaknesses using methods like vulnerability scanning, penetration testing, red teams, and code review provides invaluable data on where organisations are exposed. This allows precise targeting of cybersecurity program investments.

Critical aspects include:

- Vulnerability management – Systematically scanning networks, endpoints, apps, and clouds for misconfigurations and software flaws falling back on vendors for remediation where possible
- Penetration testing – Ethically hacking systems using real-world techniques to quantify how much damage skilled intruders could inflict before being detected

- Red team exercises – Simulating how advanced persistent threats would infiltrate networks, move laterally to high-value targets, and exfiltrate data over time
- Code auditing – Reviewing application source code line-by-line to uncover weaknesses left accidentally or intentionally by developers

As these domains demonstrate, security is a fast-growing field with diverse and rewarding career paths with lots of opportunities on the horizon. Whether just starting out or already working in tech, specialising in one or more of these areas will provide value to any organisation and allow professionals to make a real impact in strengthening the connected world's defences. Though threats will only accelerate, so will breakthroughs in security technology, best practices, and talent.